API Documentation

A practical reference for the fictional master-data service. Examples use the initial sample data.

Endpoint reference

Base URL for a local run: **http://localhost:8080**. The CSRF and login endpoints are accessible before authentication. All other endpoints require a logged-in session.

Method and path	Purpose	Status
GET /api/auth/csrf	Get a session-bound CSRF token	200
POST /api/auth/login	Authenticate with form fields	200
POST /api/auth/logout	End the session	204
GET /api/stores	Search stores by province name	200
GET /api/whitelist	List visible whitelist members	200
PUT /api/branches/{id}	Update a branch	204
DELETE /api/branches/{id}	Soft-delete a branch	204
POST /api/whitelist/{storeId}	Add a visible store	201
DELETE /api/whitelist/{storeId}	Remove a whitelist entry	204

How to use the examples

Requests below are HTTP examples suitable for Postman or another API client. Preserve the session cookie between requests. Values in angle brackets are placeholders, not literal credentials or tokens.

The application user is the evaluation account configured when the application starts. It is separate from the MySQL database account. See the README for setup and a Postman walkthrough.

1. Authenticate and keep the session

First request a CSRF token. Keep the session cookie returned by the server, then send the token in the response's named header when logging in.

Request a token

```
GET /api/auth/csrf

200 OK
{
  "headerName": "X-CSRF-TOKEN",
  "token": "<csrf-token>"
}
```

Log in using form fields

```
POST /api/auth/login
Content-Type: application/x-www-form-urlencoded
X-CSRF-TOKEN: <csrf-token>
Cookie: JSESSIONID=<session-cookie>

username=<evaluation-username>&password=<evaluation-password>

200 OK
{"message":"authenticated"}
```

Use the actual **headerName** and token returned by the server. After login, fetch **GET /api/auth/csrf** again using the authenticated session. Use that fresh token for POST, PUT and DELETE requests. The session cookie may change at login, so let your client keep the latest cookie.

Log out

```
POST /api/auth/logout
X-CSRF-TOKEN: <fresh-csrf-token>
Cookie: JSESSIONID=<session-cookie>

204 No Content
```

2. Search and read stores

Province search is a case-insensitive literal substring match: **Bal** matches Bali. A term may match several provinces. Percent and underscore are treated as literal characters. A term with no matching active, non-deleted province returns 404.

```
GET /api/stores?province=Bal&page=0&size=2
Cookie: JSESSIONID=<session-cookie>
```

Example response: initial fictional data

```
200 OK
{
  "content": [
    {
      "id": 1, "name": "Bali Sample One",
      "branchId": 1, "branchName": "Bali Central",
      "provinceId": 1, "provinceName": "Bali"
    },
    {
      "id": 2, "name": "Bali Sample Two",
      "branchId": 1, "branchName": "Bali Central",
      "provinceId": 1, "provinceName": "Bali"
    }
  ],
  "page": 0, "size": 2,
  "totalElements": 3, "totalPages": 2
}
```

The second page contains the initially whitelisted Jakarta store. The search combines stores from matching provinces with globally whitelisted stores, removes duplicates and orders by store ID.

A store is visible only when it, its branch and its province are all active and not deleted. This rule also applies to whitelist results. **GET /api/whitelist?page=0&size=25** returns the same page format.

Pages are zero-based. The default page size is 25; the configured maximum defaults to 100. Results and totals can change when data changes between requests.

3. Change branches and whitelist membership

Use the authenticated session and refreshed CSRF token for each request. Successful changes and their audit records are saved in the same transaction.

Update a branch

```
PUT /api/branches/1
Content-Type: application/json
X-CSRF-TOKEN: <fresh-csrf-token>
Cookie: JSESSIONID=<session-cookie>

{
  "name": "Bali Central Updated",
  "active": true
}

204 No Content
```

Both fields are required. The name must be nonblank and at most 120 characters. This endpoint does not change the branch's province.

Add or remove a whitelist entry

```
POST   /api/whitelist/1     -> 201 Created
DELETE /api/whitelist/1     -> 204 No Content
DELETE /api/branches/4      -> 204 No Content
```

A store must be visible when added. An entry can later be removed by ID even if the store becomes hidden. With the default deletion policy, a branch with any non-deleted stores cannot be deleted, including when those stores are inactive. The optional **HIDE_STORES** policy soft-deletes the branch and hides its stores.

Common responses

400 invalid input. **401** missing authentication or invalid credentials. **403** access denied or invalid CSRF token. **404** resource or matching province not found. **409** duplicate membership or rejected deletion. **500** unexpected error.

The examples assume the initial sample state. Earlier changes can change the result of later requests.